

文件编号：ITSS-06-01-11

版 本：V1.0

天津通海信息技术有限公司

信息安全管理制

编制人：耿宁 编制时间：2025.7.3

审核人：常海霞 审核时间：2025.7.3

批准人：尹兆铨 审批时间：2025.7.3

修订记录

日期	版本	变更说明	编写人	审核人	批准人
2025.7.3	V1.0	新建文档	耿宁	常海霞	尹兆铮

目录

天津通海信息技术有限公司 1

信息安全管理制度 1

1. 目的 4

2. 原则 4

3. 适用范围 4

4. 岗位职责 4

 4.1. 运维部 4

5. 信息安全管理流程 5

 5.1. 过程描述 5

 5.1.1. 需求识别和分析 6

 5.1.2. 确定安全实施范围 6

 5.1.3. 信息安全风险评估 6

 5.1.4. 设计安全规范 6

 5.1.5. 实施安全规范 6

 5.1.6. 监控安全状况 7

 5.1.7. 维护安全规范 7

 5.1.8. 信息安全报告 7

 5.2. 信息安全策略 8

 5.2.1. 风险识别 8

 5.2.2. 风险评估 8

 5.2.3. 风险值计算与评价 9

 5.2.4. 风险处置 10

 5.2.5. 定期评估 10

 5.2.6. 信息安全培训 10

 5.3. 考核指标 11

6. 附则 11

7. 附件 11

8. 记录 11

1. 目的

本制度的目的是在客户服务工作中有效管理信息安全，主要包含以下几点：

1. 满足信息系统集成、软件运维项目运行和客户服务中的安全性需求以及合同、法律和外部政策等外部要求；
2. 提供一个满足需求的基本的信息系统安全基线；
3. 确保有效的信息安全措施在公司、运维部与研发部和服务台三个层面都得到贯彻。

2. 原则

在保障可用性的前提下，保护信息的机密性与完整性，并基于风险实施全面、持续、闭环的管理。

3. 适用范围

适用于运维服务过程中所有部门

4. 岗位职责

4.1. 运维部

1. 监控安全管理流程；
2. 根据组织安全需求，开发与维护安全计划；
3. 处理与安全相关的问题和事件；
4. 确保满足SLA中指定的安全需求；
5. 完成包含流程结果，自评估及内部审计的信息安全风险评估报告；
6. 负责制定运维安全范围和规范、表格。
7. 负责安排项目中的信息安全风险评估；
8. 做好用户的沟通，协调关于信息安全的问题。
9. 负责该项目安全管理的严格实施和持续监控。
10. 出安全报告给用户。
11. 负责记录系统运行过程中的信息安全事件记录。

12. 负责现场处理系统运行过程中的信息安全事件。

5. 信息安全管理流程

信息安全管理流程，如图5-1所示

图5-1 信息安全管理流程



5.1. 过程描述

信息安全活动划分为三个部分，包括规划、实施和监控。规划包括需求识别和分析、确定安全实施范围、信息安全风险评估、安全规范设计；实施包括安全规范实施；监控包括安全状况监控、维护安全规范、信息安全报告。

5.1.1. 需求识别和分析

根据服务级别协议中签订的关于安全的详细说明，确定安全需求并进行分析。服务级别协议中应该定义安全需求，在可能的情况下还应该以可测度的术语进行定义。该协议的安全部分应当确保客户所有的安全需求和标准能够实现，并且实现的结果能够进行明确的验证。需求识别的范围包括人员安全、数据安全、机房环境、设备安全、系统安全等的安全需求。

5.1.2. 确定安全实施范围

根据安全需求的识别情况确定安全实施范围。安全实施范围包括列为相应安全等级的数据、人员、机房、设备、系统等。

5.1.3. 信息安全风险评估

运维服务人员根据确定的安全实施范围进行风险分析与评估工作，并提交风险分析与评估报告。

风险评估包括识别安全实施范围内的资产状况、资产面临的威胁，在使用的技术方法和管理规范，进行总体分析得出风险的等级，编制《风险评估报告》。

5.1.4. 设计安全规范

根据《风险评估报告》，运维服务人员制定和编写《信息安全管理制度》。并根据信息安全规范制定信息安全策略、针对个人的保密协议、岗位职责说明、机房管理制度。

5.1.5. 实施安全规范

在设计好安全规范后，日常需按照安全规范来实施安全管理。

1. 在人员安全方面的实施：
 - (1) 职位说明中的任务和职责；
 - (2) 安全防护；
 - (3) 针对个人的保密协议；
2. 责任划分的实施，以及岗位分离的实施；

3. 书面的操作指示，内部规章；
4. 安全问题涉及整个生命周期，应针对系统开发、测试、验收、运营、维护和终止制定安全指南；
5. 将开发和测试环境与实际的运营环境分离开来；
6. 处理事件的制度；
7. 恢复设施的实施；
8. 为变更管理提供信息输入，病毒防护措施的实施；
9. 针对计算机、操作系统、应用系统、数据、网络和网络服务的安全管理措施的实施；
10. 数据媒介的处理和安全。

5.1.6. 监控安全状况

对安全规范实施进行监控，在工作周报、服务月报中体现。

对发生的信息安全事件按照《事件管理制度》执行。

5.1.7. 维护安全规范

运维服务人员根据系统运行及客户服务的风险变化，必要时对《信息安全管理制度》进行修改。

由于基础架构、组织和业务流程方面的变化导致相关的风险也随着发生变化，因此安全也需要进行维护。

安全维护包括服务级别协议中安全部分的维护以及详细的安全规范的维护。

维护需要根据评估子系统流程的结果以及对风险变化的评估结果进行。这些建议既可以直接被计划子流程所采纳，也可以纳入总体的服务级别协议的维护中。

安全规范更新通过变更管理实施,参照《变更管理制度》。

5.1.8. 信息安全报告

运维服务人员根据信息安全的实施状况及日常发生的安全事件等，每季度一次巡检，如发生信息安全事件则编写《信息安全服务报告》。

报告可以提供有关已实现安全绩效方面的信息，并可以了解有关的安全问题。

正确地了解有关措施（如安全措施的实施）所取得的效率以及实际被采用的安全措施。

除了在特殊情形下的例外事项，报告都是通过运维服务人员进行传达的。

根据信息安全管理需要报告信息安全的实施情况，并提交给《服务报告》中。
参照《服务报告管理制度》

5.2. 信息安全策略

5.2.1. 风险识别

1. 识别风险

识别威胁与脆弱性：基于已识别的资产清单，逐项描述潜在风险并确定其来源。风险的判断可参照《机房环境》、《系统与网络》及《应用系统安全管理规范》。

威胁：识别来自资产外部的风险因素（如恶意攻击、自然灾害）。

脆弱性：识别资产自身存在的内部缺陷或弱点（如系统漏洞、配置不当）。

嵌入变更管理：在变更审批流程中，必须主动识别因变更可能引发的信息安全风险。信息安全风险评估结果应作为变更决策的关键依据，对于任何违反既定安全要求的变更操作，必须予以终止。

2. 确认已经存在的防护及控制措施

梳理现有措施：针对已识别的各项资产，确认并记录已实施的技术与管理控制措施（参照上述各项安全管理规范）。

评估措施有效性：当IT基础架构因变更而发生变化时，必须对原有防护措施进行重新评估，确保其仍能有效应对新的风险态势，持续满足组织的安全目标。

5.2.2. 风险评估

1. 实施依据

风险评估应依据公认的国际或国家标准（如ISO/IEC 27005《信息技术-安全技术-信息安全风险管理》）开展。具体实施前，需制定详细的《风险评估实施计划》，以明确范围、方法、资源与时间表。

2. 评估方法

风险评估采用半定量分析法，主要综合考量以下两个维度：

风险发生概率：预估风险事件发生的可能性，按以下标准进行分级评分：

范围	得分
1%至20%	1
21%至40%	2
41%至60%	3
61%至80%	4
81%至100%	5

资产重要度：依据资产的财务价值及其所支撑业务服务的关键性进行综合评定。两项指标中任一项评价为“高”，则资产重要度等级即为高。

原值	关联的服务重要度	得分
低	低	1
较低	较低	2
中	中	3
较高	较高	4
高	高	5

5.2.3. 风险值计算与评价

风险值 = 资产重要度得分 × 风险概率得分

计算结果范围为1至25。

风险等级判定：依据计算出的风险值，结合组织实际情况，划分高、中、低风险等级区间。

确定可接受水平：组织需依据风险评估结果，并综合考虑控制成本与业务紧迫性，确定可接受的风险水平基准值。风险处置单如下图：

风险处置单			
资产名称	xx防火墙	所属项目	运维系统
风险描述	风险来源	风险评估扫描	
	风险等级	3级（中风险）	
	风险威胁	TC01软硬件故障	

	脆弱性	VM08存在单点故障
建议处置措施	作为运维网和生产网之间的边界安全设备，没有冗余设备，存在单点故障风险。出现故障时会影响到XXX系统的正常使用。建议采购一台XXX防火墙替换现有的XXX防火墙，用原有的防火墙作为热备设备。	
处置结果确认	签字： 日期：	
客户方确认意见	签字： 日期：	

5.2.4. 风险处置

对于评估结果超出可接受风险水平基准的风险，必须启动风险处置流程。根据评估结论开立《风险处置单》，明确责任人与完成时限，调配资源执行处置措施（如降低、转移、规避或接受风险），以确保残余风险降至组织可接受的范围之内。

5.2.5. 定期评估

每年度至少一次全面审查风险评估内容与状态的适应性，以确定是否存在新的风险及是否需要增加新的控制措施，对发生以下情况需及时进行风险评估：

- 当发生重大信息安全事故时；
- 当信息网络系统发生重大变更时；
- 当新增加服务/资产项时；
- IT服务委员会确定有必要时。

5.2.6. 信息安全培训

运维相关部门须定期评估项目运维的实际需求与知识缺口，并据此系统性地规划并实施相关培训。

5.3. 考核指标

指标度量性	计算方式	频次	指标要求
客户信息泄露次数	服务过程中不得发生客户信息泄露	每年度	0次
信息安全事件客户投诉	服务过程中不得发生信息安全事件客户投诉	每年度	0次

6. 附则

- 1. 本制度最终解释权和修订权归运维部。
- 2. 本制度自颁布之日起施行。

7. 附件

- 《服务报告管理制度》
- 《事件管理制度》
- 《变更管理制度》

8. 记录

- 《风险评估报告》
- 《信息安全服务报告》
- 《信息安全管理制